

Escalating threats, innovative technology and greater connectivity – the importance of ISO/IEC 27001 and its evolution

WHITE PAPER





The evolution of cyber threats

With Industry 4.0 and the Internet of Things (IoT), cyber threats have become more sophisticated and nearly a daily occurrence. These attacks do not just affect the targeted enterprise, but their business partners, suppliers and customers.

The global pandemic and Russia-Ukraine war have also put cyberattacks in the spotlight. The conflict has shown that warfare is not just confined to the battlefield, but also fought in the digital domain, as state-sponsored threat actors try to spread disinformation and destabilize critical infrastructure.

Organizations, individuals and nations must keep pace with the evolution of cyber threats and implement the latest protection measures to avoid data loss, lawsuits and reputational damage, among other factors.

Defining threats

Information security

Information security, also known as InfoSec, refers to the processes and tools used to protect sensitive business information from modification, disruption, destruction and inspection.

Cybersecurity

Cybersecurity is the practice of protecting systems, networks and programs from digital attacks. These cyberattacks are usually aimed at accessing, changing or destroying sensitive information, extorting users' money or interrupting normal business processes.

Privacy protection

Privacy protection is keeping personal information from getting into the wrong hands, such as hackers. The definition varies from person to person.

Top 10 threats

1. TECHNOLOGY WITH WEAK SECURITY

Technology is evolving faster than ever. More often than not, new technologies have internet access, but no security plan. This creates a severe risk, as each unsecured connection means vulnerability.

2. SOCIAL MEDIA ATTACKS

Cybercriminals constantly find new ways to exploit social media users and their private information. One malicious way is to use emojis and emoticons to get the user to let their guard down.

3. MOBILE MALWARE

Security experts have seen risks in mobile device security since these devices began connecting to the internet. Furthermore, mobile phone users are often nonchalant towards threats. Considering our relentless reliance on mobile phones and how little cybercriminals have targeted them, large threats are a distinct possibility.

4. THIRD-PARTY ENTRY

Cybercriminals prefer the path of least resistance. The Microsoft Exchange Server was the victim of a massive cyberattack in March 2021. This disrupted nine government agencies and 60,000 private companies.

5. NEGLECTING PROPER CONFIGURATION

Big data tools can be customized to fit an organization's needs. Companies continue to neglect the importance of adequately configuring security settings. Fifth Third Bank was the victim of one of 2020's most significant data breaches, due to a former employee retaining access.

6. OUTDATED SECURITY SOFTWARE

Updating security software is a basic technology management practice and mandatory for protecting data. Software is developed to defend against known threats. This means any new malicious code that hits outmoded security software will go undetected.

7. SOCIAL ENGINEERING

Cybercriminals know that intrusion techniques have a shelf life. They have turned to reliable, non-technical social engineering that relies on social interaction and psychological manipulation to gain access to confidential data. This form of intrusion is unpredictable and effective.

8. LACK OF ENCRYPTION

Protecting sensitive data in transit and at rest is a measure few industries have embraced, despite its effectiveness. The healthcare industry handles extremely sensitive data and understands the gravity of losing it, so many stakeholders place heavy emphasis on encryption.

9. CORPORATE DATA ON PERSONAL DEVICES

Whether an organization distributes corporate phones or not, confidential data is still being accessed on personal devices. Mobile management tools limit functionality, but securing the loopholes is not a priority for many organizations.

10. INADEQUATE SECURITY TECHNOLOGY

Investing in network security-monitoring software has become a growing trend after 2014's painful rip of data breaches. The software is designed to alert when intrusion attempts occur, but these alerts are only valuable if someone addresses them. Companies rely too heavily on technology to fully protect against attacks when it is meant to be a managed tool.

The standout safeguarding standard – ISO/IEC 27001

A legendary lineage

ISO/IEC 27001 can be traced back to British Standard 7799, written by the UK Department of Trade and Industry (DTI) and published in 1995.

PART 1

BS 7799's first part, containing information security management best practices, was revised in 1998. After much debate between standards bodies worldwide, it was adopted by ISO and IEC and became ISO/IEC 17799 – Information Technology – Code of Practice for Information Security Management

– in 2000. This was revised in 2005, including a slight name change. ISO and IEC finally incorporated this part into the ISO/IEC 27000 family as ISO/IEC 27002:2007.

PART 2

The second part, titled Information Security Management Systems – Specification with Guidance for Use – was first published just before the millennium. This element focused on how to implement an information security management system (ISMS), referring to the structure and controls needed. This later became ISO/IEC 27001:2005.

PART 3

The third part was published in 2005, covering risk analysis and management. It aligned with ISO/IEC 27001:2005.

UNITING PARTS 1–3

Following revisions, much time and some unification, ISO and IEC created ISO/IEC 27001:2013 – the internationally recognized, best-practice information security standard to help organizations keep intellectual property and information assets secure.



The importance of ISO/IEC 27001 certification

Adopted by tens of thousands of organizations, ISO/IEC 27001 certification demonstrates an organization's commitment to information security and provides assurance to clients and other partners that it is serious about protecting information under its control.

The standard is technology agnostic, so it does not matter what technology environment you have. It is written in such a way that any organization, from small business to large multi-billion dollar enterprise, can use it.

ISO/IEC 27001 specifies the requirements to establish, implement, maintain and continually improve an ISMS for safety and security. It also includes requirements for assessing and treating information security risks, tailored to your needs.

Because it is a management system standard, it aligns with other globally recognized standards like:

- ISO/IEC 27701 (privacy management)
- ISO/IEC 20000-1 (IT service management)
- ISO 22301 (business continuity)
- ISO 9001 (quality)
- ISO 14001 (environmental)
- ISO 45001 (occupational health and safety)

This alignment allows you to implement the requirements of several of these standards within your organization with minimal effort while benefiting from the synergy effects.

Based on the CIA Triad

Implementing an ISMS demonstrates your dedication to protecting the confidentiality, integrity and availability (CIA) of information under your control.

The standard aligns with the CIA Triad, which provides vital security features. It helps you to avoid compliance issues, supports business continuity and prevents reputational damage.



This means ISO/IEC 27001 covers:

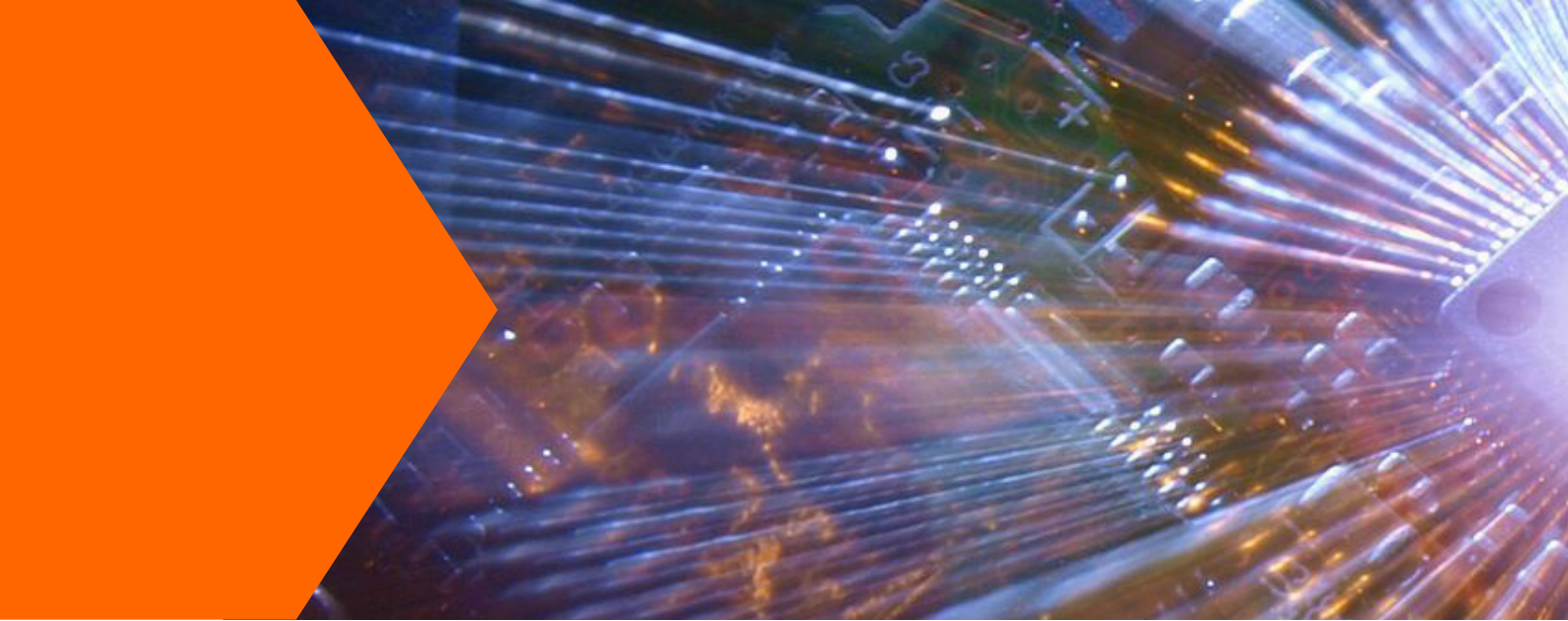
- Information security policies
- Communications security
- Organization of information security
- Supplier relationships

- System acquisition, development and maintenance
- Asset management
- Human resources security
- Access control
- Information security incident management
- Cryptography
- Compliance
- Information security aspects of business continuity management
- Physical and environmental security
- Operations security

What are the key benefits?

ISO/IEC 27001 can lead to:

- Enhanced credibility
- Reduced risk of fraud, information loss and disclosure
- Demonstration of integrity to your system
- Business culture transformation and greater awareness of the importance of keeping information secure
- New business opportunities with security-conscious customers
- A stronger notion of confidentiality throughout the workplace
- Better preparedness for the unavoidable – the next security event or incident



Evolution to meet the threats

The time to update

ISO/IEC 27001 was last updated in 2013 and the cyber world and threats to it have dramatically evolved, becoming increasingly complex with more innovative technology, cloud operations and online business. The standard must follow suit and is malleable to accommodate updates.

February 15, 2022, was a crucial day. ISO/IEC 27002:2022 – Information Security, Cybersecurity and Privacy Protection – Information Security Controls – was published. Due to this, ISO/IEC 27001 Annex A needed updating to align with ISO/IEC 27002:2022's controls.

The main changes in ISO/IEC 27001:2022

The following is from the Final Draft International Standard (FDIS) and further significant changes are not expected in ISO/IEC 27001:2022. For further details, read our [Comparing ISO/IEC FDIS 27001 to ISO/IEC 27001:2013. What are the Changes?](#) guidance document.

THE TITLE

The name has been changed to reflect the standard's true scope. It is ISO/IEC 27001:2022 – Information Security, Cybersecurity and Privacy Protection – Information Security Management Systems – Requirements. This also aligns with ISO/IEC 27002:2022's new title.

CLAUSE NUMBERING

New subclauses have been introduced to further harmonize the document's structure with other management system standards, such as ISO 9001 and ISO 22301.

Two subclauses – 10.1 and 10.2 – have also been interchanged. 10.1 is Continual Improvement while 10.2 is Nonconformity and Corrective Action. There are no changes in their requirements.

NEW TEXT

Although new text has been added and some rearranged, these changes only clarify the requirements and do not add new ones to the standard.

ANNEX A

Annex A's title is now Information Security Controls Reference and the controls have been revised to align with ISO/IEC 27002:2022. In the 2013 edition, only the descriptions of the controls are derived from ISO/IEC 27002.

OTHER CHANGES

There have been some updates to several clauses. Our [guidance document](#) precisely outlines the differences between the FDIS and 2013 documents, and provides our remarks to assist you.



Strong family ties

The main changes in ISO/IEC 27002:2022

As mentioned, a lot of ISO/IEC 27001 updates are due to ISO/IEC 27002 evolving. Below is a summary of the latter's changes. For further details, read our [Key Changes in the ISO/IEC 27002:2022](#) white paper.

NUMBER OF CONTROLS

ISO/IEC 27002:2022 has 93 controls versus 114 in 2013's version.

CONTROL CATEGORIES

Controls are regrouped into four categories – Organizational, People, Physical and Technological – instead of 14 themes and 36 categories in the 2013 edition.

The four-categories layout emphasizes that protecting information and data is more than merely by technological means. To achieve the information security outcomes, technological controls are just the remedies to prevent or mitigate information security risks.

More importantly, the top management of organizations must set out the information security management framework and direction, as well as identify and communicate the importance and impacts of different information to the business.

Besides, this new control layout can facilitate management to assign responsibilities within the organization for information security enhancement.

NEW CONTROLS

There are 11 new controls to address the evolvement in technologies and industrial practices:

1. Threat intelligence
2. Information security for use of cloud services
3. ICT readiness for business continuity
4. Physical security monitoring
5. Configuration management
6. Information deletion
7. Data masking
8. Data leakage prevention
9. Monitoring activities
10. Web filtering
11. Secure coding

MERGED CONTROLS

Twenty-four controls in the 2022 edition are the result of merging some from the 2013 version. Merging means a reduced number of controls, thus a leaner standard.

ATTRIBUTES

ISO/IEC 27002:2022 introduces attributes for each control. Each control is associated with five attributes with corresponding attribute values.

1. Control types – preventative, detective, corrective.
2. Information security properties – confidentiality, integrity, availability.
3. Cybersecurity concepts – identify, protect, detect, respond, recover.

4. Operational capabilities – governance, asset management, information protection, human resource security, physical security, system and network security, application security, secure configuration, identity and access management, threat and vulnerability management, continuity, supplier relationships security, legal and compliance, information security event management, information security assurance.
5. Security domains – governance and ecosystem, protection, defense, resilience.

PURPOSE REPLACES OBJECTIVE

The 2022 version uses Purpose and not Objective. Each control has a purpose defined to illustrate why the control should be implemented.

OTHER CHANGES

The title now includes Information Security, Cybersecurity and Privacy Protection – Information Security Controls to reflect the standard's breadth. Code of Practice is removed to indicate that the document is a reference to generic information security controls.

ISO/IEC 27000 is no longer the normative reference of ISO/IEC 27002:2022. Instead, the terms and definitions in 2022's Clause 3 apply. Users of the 2022 edition are recommended to refer to its terms and definitions to facilitate their understanding of the controls and guidance in the document.



Conclusion

ISO/IEC 27001 provides a solid governance framework and allows any organization to manage local, regional and global information security and cybersecurity regulations.

It is the go-to standard as cyber threats evolve. Many reasons, including intensifying threats, technology advancements and superior connectivity, such as 5G, could make your business a target for cybercriminals.

These changes do, indeed, beget changes. A key strength of ISO/IEC 27001 is its ability to keep pace in an ever-changing cyber world.

Although 2022's updates make the documentation and guidelines heftier, and add more responsibilities, there are clear and detailed explanations of each control.

As expected, the most significant change is Annex A's revisions to align with ISO/IEC 27002:2022 security controls.

Changes to Clauses 4–10 are minor editorial changes to further harmonize the structure with other management system standards.

If your organization is already ISO/IEC 27001 compliant, no changes in technology are needed, just updates in the documentation. You might need to revise internal policies, according to the new subclauses and modified requirements. Your risk assessment result and risk treatment plan(s) should also be reviewed and Statement of Applicability (SoA) updated.

The transition period will be three years from when ISO/IEC 27001:2022 is officially published, so you should have ample time to comply. Your ISO/IEC 27001 certificate remains valid until this period ends.

How we can help

We can support you whether you want a smooth transition or first certification to ISO/IEC 27001:2022. We have created a suite of services and materials, including transition training and guidance documents on ISO/IEC 27001 and ISO/IEC 27002 updates.

We can ensure that you have adapted the documentation within the transition period. Therefore, no new audit(s) need to be scheduled because this will take place during your regular surveillance audits. Furthermore, additional time to assess the successful transition will be required as per the International Accreditation Forum's (IAF) [MD 26:2022 document](#).

However, when you renew your certification during the transition period, you could work to the new controls to avoid leaving it until the eleventh hour.

Whether a current client or new to ISO/IEC 27001, we can support you through the changes and certification process.



www.sgs.com



certification@sgs.com

A protective pioneer for decades

With expertise in all major industries, we know what information security, cybersecurity and privacy protection, among other digital issues, mean to organizations, whatever their size, purpose and complexity.

Our ever-evolving portfolio can improve your efficiency while guiding you towards compliance with internationally recognized regulations. Our certification schemes cover many areas, including data processing and protection, cloud storage, facility and lottery security, and responding to business-critical events.

Some key services

ISO/IEC 27001 CERTIFICATION

Certification is evidence of an independent review of your effective implementation of a robust ISMS based on globally recognized best practices. This provides assurance internally and, more importantly, to business partners that your organization takes information security, cybersecurity and privacy seriously, as well as demonstrates C-level commitment.

ISO/IEC 27701 CERTIFICATION

ISO/IEC 27701, an extension to ISO/IEC 27001, addresses the protection of privacy information like date of birth and national identification numbers. A privacy information management system (PIMS) provides a framework for controllers and processors to manage personally identifiable information (PII).

Certification allows an organization to efficiently implement compliance with new regulatory requirements and personal data privacy laws around the world.

TRAINING

Our expert instructors provide consistent, effective and high-quality training to ensure that your employees have the latest skills to enhance your organization. Our training methods include public, in-house, eLearning, virtual and blended learning.

Understanding ISO/IEC 27001:2022, its updates and transition period can be disorientating. We have created a Transition Training Course that provides detailed comparisons and descriptions of the changes, among other details. This is part of a comprehensive training portfolio concerning digital and ICT.

OTHER CERTIFICATION AND TRAINING SOLUTIONS

These include:

- Cybersecurity Maturity Model Certification (CMMC) Training
- Cloud Security Alliance (CSA) Security, Trust, Assurance and Risk (STAR)
- ISO/IEC 20000, IT – Service Management
- ISO 22301, Business Continuity Management Systems (BCMS) – Requirements
- ISO/IEC 27017, Code of Practice for Information Security Controls Based on ISO/IEC 27002 for Cloud Services
- ISO/IEC 27018, Code of Practice for Protection of PII in Public Clouds Acting as PII Processors
- World Lottery Association-Security Control Standard:2020 (WLA-SCS:2020)

References

Forbes – <https://www.forbes.com/sites/bernardmarr/2022/03/18/the-biggest-cyber-security-risks-in-2022/?sh=7994336c7d7b>.

Georgetown University (US) – <https://scsonline.georgetown.edu/programs/masters-technology-management/resources/top-threats-to-information-technology>.

Privacy Affairs – <https://www.privacyaffairs.com/cybersecurity-attacks-in-2021/>.

Identity Force – <https://www.identityforce.com/blog/2020-data-breaches>.

ISMS.online – <https://www.isms.online/iso-27001/>.

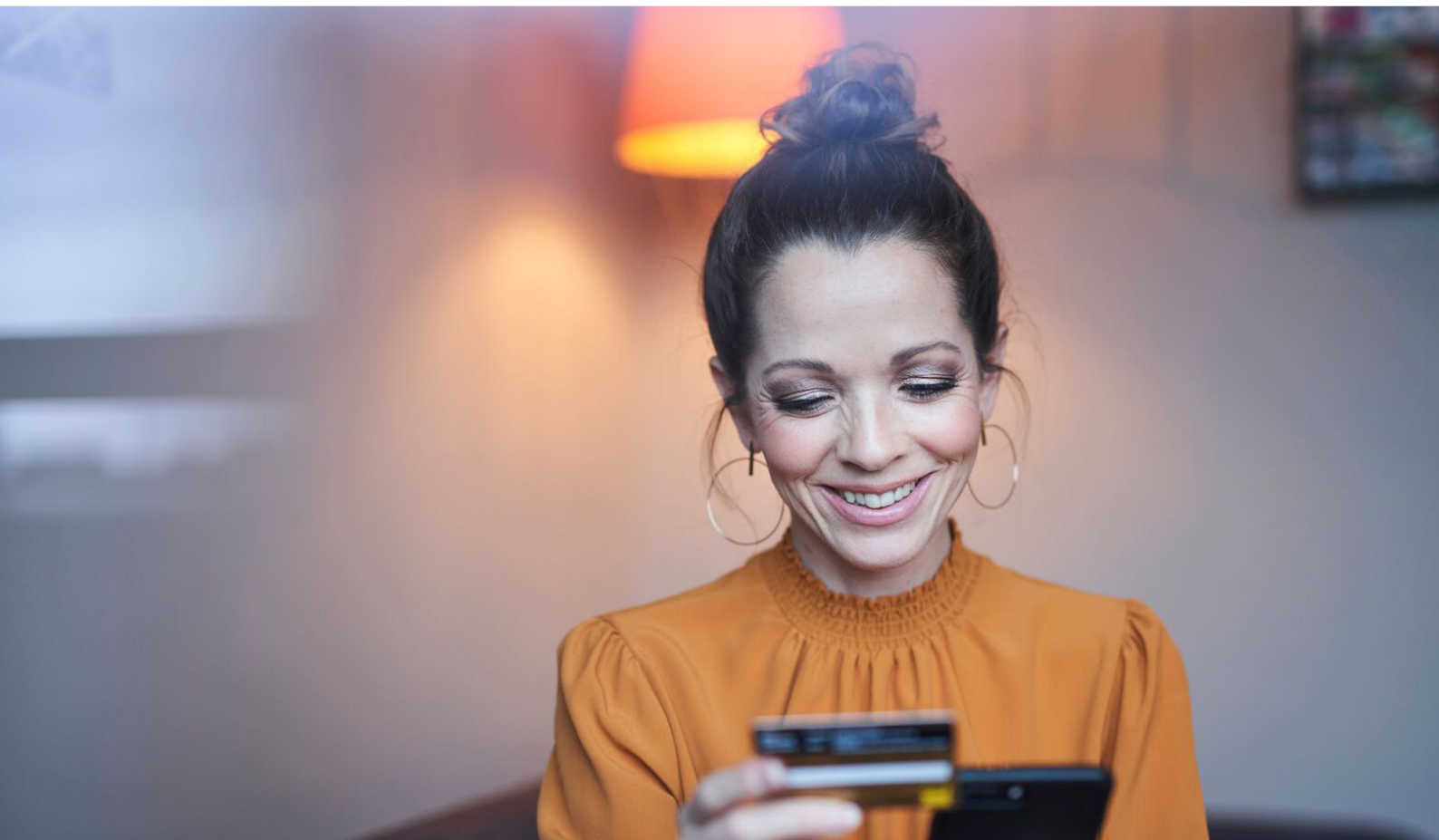
CISCO – <https://www.cisco.com/c/en/us/products/security/what-is-information-security-infosec.html>.

https://www.cisco.com/c/en_uk/products/security/what-is-cybersecurity.html.

SGS – www.sgs.com.

ISO – <https://www.iso.org/home.html>.

IAF – https://iaf.nu/iaf_system/uploads/documents/IAF_MD_26_Transition_requirements_for_ISOIEC_27001-2022_09082022.pdf.



WWW.SGS.COM

SGS Headquarters
1 Place des Alpes
P.O. Box 2152
1211 Geneva 1
Switzerland



WHEN YOU NEED TO BE SURE

SGS